



**UNIVERSIDAD TECNOLÓGICA
DE QUERÉTARO**

Alumna:

Vasquez Noyola Andrea

Grupo:

IDGS17

Matrícula:

2023148002

Materia:

Seguridad en el Desarrollo de Aplicaciones

Práctica 2 - Parte 1

Durante las pruebas realizadas en el entorno local de VulnerableApp, se identificó y explotó con éxito una vulnerabilidad crítica en el módulo de búsqueda de usuarios. Los detalles técnicos del hallazgo se documentan a continuación:

Elemento	Descripción esperada
CWE	CWE-89
OWASP	Injection
Impacto	Exposición de datos por consulta no parametrizada
Ubicación	SearchController.Index

La vulnerabilidad radica en la forma en que se construye la consulta a la base de datos dentro del controlador. El código vulnerable concatena directamente la entrada del usuario con la cadena de la consulta SQL de la siguiente manera:

```
string query = "SELECT * FROM Users WHERE Username LIKE '%" + search + "%'";
```

Entonces, al ingresar la cadena manipulada **' OR '1'='1'** en el campo de búsqueda, el motor de la base de datos interpreta los caracteres de una forma imprevista.

La primera comilla simple es interpretada como el inicio del parámetro de búsqueda (LIKE '%'), mientras que el operador OR se toma como una segunda condición a la condición de la consulta, y por último la expresión **'1'='1'** se toma como una afirmación matemática, haciendo que se tome como si toda la consulta fuera verdadera.

Al concatenar esta entrada maliciosa, la consulta hace que el servidor realmente ejecute en la base de datos lo siguiente:

```
SELECT * FROM Users WHERE Username LIKE '%' OR '1'='1'
```

En otras palabras, mientras se lee la consulta resultante:

```
SELECT * FROM Users WHERE Username = " OR '1'='1' AND Password = " OR '1'='1'
```

lo lee como `Username = ''`; no hay un usuario que no tenga nombre o que esté vacío, así que es falso, pero, leyendo lo que queda de la consulta, dice que **○** si $1=1$ que prácticamente lo deje pasar porque esta afirmación matemática es cierta, y lo mismo para con el campo de la contraseña, por lo tanto, se burla al sistema con una afirmación matemática. Esto pasa porque cuando se usa el operador OR basta con que una afirmación de las dos sea cierta para que la condición sea verdadera para que el sistema lo valide. Aparte, el sistema no solo devuelve un solo usuario, sino que devuelve toda la lista de usuarios.